

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

PCI DSS v4.0.1

**** Seguridad del pago práctico, verificación del cumplimiento y herramientas de código abierto****

Un manual de trabajo para administradores, analistas junior, estudiantes, cambiadores de carrera, comerciantes y proveedores de servicios

Alberto (Al) Leiva

Primera edición • Julio 2026

Inside: Actual PCI DSS v4.0.1 • todos los 12 requisitos • análisis • SAQs and ROC • e-commerce • evidencia • herramientas • laboratorios • preparación de la carrera |

|. |

Publication and Use Notice

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Propósito: Educación gratuita y práctica para directivos, estudiantes, cambiadores de carrera, analistas junior, comerciantes, proveedores de servicios y profesionales de la ciberseguridad.

Aviso educativo y legal

Este manual proporciona educación general. No es asesoramiento legal, una publicación del Consejo de Normas de Seguridad de la PCI, un informe sobre el cumplimiento, una certificación del cumplimiento, un cuestionario de autoevaluación o una garantía de cumplimiento o seguridad. Sólo los documentos oficiales de validación estándar y aplicables rigen una evaluación. Las marcas de pago, los compradores, clientes, reguladores, contratos y leyes pueden imponer requisitos adicionales.

Uso ético y autorizado

Usar herramientas técnicas únicamente en sistemas, redes, aplicaciones, cuentas de nube, páginas de pago y datos que posees o estén específicamente autorizados por escrito para evaluar. Use datos de cuenta sintética en laboratorios. Nunca utilice PAN real, datos de autenticación sensibles, información de clientes, credenciales o sistemas de pago de producción en una demostración pública o carterá.

Prefacio

Una introducción acogedora a la seguridad de pago y el cumplimiento basado en pruebas.

PCI DSS protege los datos de la cuenta de pago mediante una base de referencia de los requisitos técnicos y operacionales. La parte difícil no es memorizar doce partidas. Se trata de entender dónde fluyen los datos de la cuenta, definiendo el verdadero entorno de datos de los titulares de tarjetas, controlando cada sistema que pueda afectar su seguridad, aplicando las salvaguardias consistentemente y manteniendo pruebas para apoyar cada conclusión.

PCI DSS v4.0.1 es la versión actual compatible con PCI SSC. Fue publicado en junio de 2024 como una revisión limitada al v4.0. No añadió ningún requisito y no removió ninguno. PCI DSS v4.0 retirado el 31 de diciembre de 2024. Los requerimientos v4.x actualizados en el futuro entraron en vigor el 31 de marzo de 2025 y ahora forman parte de las evaluaciones.

Este manual es el primer método. Un escáner de vulnerabilidad no reemplaza un escáner de escáner aprobado. Una política no prueba que funciona un control. Un acuerdo de proveedor de servicios no elimina la responsabilidad del comerciante de entender los deberes compartidos. Los administradores tienen su propio alcance, recursos, riesgo y remediación; los analistas hacen que esas decisiones sean más fiables mediante pruebas completas y pruebas claras.

Cómo utilizar este manual

Los administradores deben comenzar con los Capítulos 1–5 y 18–20.

Los analistas junior deben estudiar los doce capítulos requeridos, métodos de prueba, herramientas, laboratorio y capítulo de entrevista.

Los equipos técnicos deben conectar cada hallazgo al flujo de datos de cuenta, alcance de CDE, requisito, propietario, evidencia, corrección y retest.

Los comerciantes y proveedores de servicios deben confirmar instrucciones de validación con su comprador, marcas de pago, clientes, evaluador y otras entidades que aceptan el cumplimiento.

Contenido de la palabra:** La guía del capítulo a continuación contendrá números de página verificados para esta edición. El documento también contiene un campo nativo de Word TOC. Después de editar, haz clic con el botón derecho y selecciona Update Field, luego actualiza la tabla completa. |. |

Tabla de contenidos

[Notificación de publicación y uso \[2\]\(#publication-and-use-notice\)](#)

[Notificación económica y jurídica \[2\]\(#educational-and-legal-notice\)](#)

[Uso electrónico y autorizado \[2\] \(#ethical-and-authorized-use\)](#)

[Prefacio \[3\] \(#preface\)](#)

[Cómo utilizar este manual \[4\]\(#how-to-use-this-manual\)](#)

[Tabla de contenidos \[4\]\(#table-of-contents\)](#)

[1. PCI DSS v4.0.1 Foundations \[8\]\(#pci-dss-v4.0.1-foundations\)](#)

[1.1 Estado actual \[8\]\(#current-status\)](#)

[1.2 Quien y qué aplica a \[8\]\(#who-and-what-it-applies-to\)](#)

[1.3 Los seis objetivos de control \[8\]\(#the-six-control-goals\)](#)

[2. Normas de datos y protección de la cuenta \[10\]\(#account-data-and-protection-rules\)](#)

[2.1 Los métodos de protección son diferentes \[10\]\(#protection-methods-are-different\)](#)

[3. Alcance, CDE y Segmentación \[12\]\(#scope-cde-and-segmentation\)](#)

[3.1 Scope discovery \[12\]\(#scope-discovery\)](#)

[3.2 Validación del alcance \[13\]\(#scope-validation\)](#)

[4. Validación, SAQs, ROC, AOC y Rols \[14\]\(#validation-saqs-roc-aoc-and-roles\)](#)

[5. Definidos, personalizados, compensatorios y enfoques de riesgo \[15\]\(#defined-customized-compensating-and-risk-approaches\)](#)

[6. Requisitos 1 - Controles de Seguridad de la Red \[16\]\(#requirement-1-network-security-controls\)](#)

[7. Requisito 2 - Configuraciones seguras \[17\]\(#requirement-2-secure-configurations\)](#)

[8. Requisito 3 — Datos de la cuenta almacenados \[18\]\(#requirement-3-stored-account-data\)](#)

[9. Requisito 4 - Criptografía de transmisión \[19\]\(#requirement-4-transmission-cryptography\)](#)

[10. Requerimiento 5 - Software Malicious \[20\]\(#requirement-5-malicious-software\)](#)

[11. Requisito 6 - Sistemas y Software Seguros \[21\]\(#requirement-6-secure-systems-and-software\)](#)

[12. Requisitos 7 - Las empresas necesitan saber \[23\] \(#requirement-7-business-need-to-know\)](#)

[13. Requerimiento 8 - Identidad y autenticación \[24\]\(#requirement-8-identity-and-authentication\)](#)

[14. Requisito 9 - Acceso físico \[25\] \(#requirement-9-physical-access\)](#)

[\[15. Requisito 10 — Registro y Vigilancia \[26\] \(#requirement-10-logging-and-monitoring\)\] \(#requirement-10-logging-and-monitoring\)](#)

[16. Requisitos 11 - Pruebas de seguridad \[27\]\(#requirement-11-security-testing\)](#)

[17. Requisito 12 - Políticas y programas \[28\]\(#requirement-12-policies-and-programs\)](#)

18. Pruebas de prueba, evaluación y control [30](#evidence-assessment-and-control-testing)

18.1 Pruebas prácticas [30](#practical-tests)

19. Herramientas de código abierto para PCI DSS Work [32](#open-source-tools-for-pci-dss-work)

19.1 validación de herramientas [32](#tool-validation)

19.2 CISO Assistant [32](#ciso-assistant)

Inicio rápido [32](#quick-start)

Evidencia y limitación [33](#evidence-and-limitation)

19.3 Wazuh [33](#wazuh)

Inicio rápido [33](#quick-start-1)

Evidencia y limitación [33](#evidence-and-limitation-1)

19.4 osquery [33](#osquery)

Inicio rápido [33](#quick-start-2)

Evidencia y limitación [33](#evidence-and-limitation-2)

19.5 OpenSCAP [33](#openscap)

Inicio rápido [33](#quick-start-3)

Evidencia y limitación [34](#evidence-and-limitation-3)

19.6 Greenbone Community Edition [34](#greenbone-community-edition)

Inicio rápido [34](#quick-start-4)

Evidencia y limitación [34](#evidence-and-limitation-4)

19.7 Nmap [34](#nmap)

Inicio rápido [34](#quick-start-5)

Evidencia y limitación [34](#evidence-and-limitation-5)

19.8 Trivy [34](#trivy)

Inicio rápido [34](#quick-start-6)

Evidencia y limitación [35](#evidence-and-limitation-6)

19.9 OWASP ZAP [35](#owasp-zap)

Inicio rápido [35](#quick-start-7)

Evidencia y limitación [35](#evidence-and-limitation-7)

19.10 ModSecurity + OWASP CRS [35](#modsecurity-owasp-crs)

Inicio rápido [35](#quick-start-8)

Evidencia y limitación [35](#evidence-and-limitation-8)

19.11 Suricata [35](#suricata)

Inicio rápido [35](#quick-start-9)

Evidencia y limitación [36](#evidence-and-limitation-9)

19.12 Keycloak [36](#keycloak)

Inicio rápido [36](#quick-start-10)

Evidencia y limitación [36](#evidence-and-limitation-10)

19.13 DefectDojo [36](#defectdojo)

Inicio rápido [36](#quick-start-11)

Evidencia y limitación [36](#evidence-and-limitation-11)

19.14 AIDE [36](#aide)

Inicio rápido [36](#quick-start-12)

Evidencia y limitación [36](#evidence-and-limitation-12)

19.15 Agente de política abierta [37](#open-policy-agent)

Inicio rápido [37](#quick-start-13)

Evidencia y limitación [37](#evidence-and-limitation-13)

20. Manual de PCI DSS para gerentes [38](#managers-pci-dss-playbook)

20.1 Preguntas mensuales [38](#monthly-questions)

20.2 Panel [38](#dashboard)

21. From Beginner to Junior PCI Analyst [39](#from-beginner-to-junior-pci-analyst)

21.1 Trabajo junior típico [39](#typical-junior-work)

22. Laboratorio de Ficción y Cartera [40](#fictional-laboratory-and-portfolio)

Proyecto 1 — Ámbito [40] (#project-1-scope)

Proyecto 2 - Requisitos [40](#project-2-requirements)

Proyecto 3 — Datos [40](#project-3-data)

Proyecto 4 — Access [40](#project-4-access)

Proyecto 5 — Vulnerabilidades [40](#project-5-vulnerabilities)

Proyecto 6 — E-commerce [40](#project-6-e-commerce)

Proyecto 7 — Incident [40](#project-7-incident)

Proyecto 8 — Informe de gestión [40](#project-8-management-report)

23. Plan de aprendizaje de 30 días [41](#thirty-day-learning-plan)

24. Preparación de entrevistas [42](#interview-preparation)

42](#what-is-the-current-pci-dss-version)

¿Cuál es el CDE? [42](#what-is-the-cde)

¿Qué es el PAN? [42](#what-is-pan)

¿Pueden almacenarse datos de autenticación sensibles si están encriptados? [42](#can-sensitive-authentication-data-be-stored-if-encrypted)

¿Qué es la segmentación? [42](#what-is-segmentation)

¿Definido contra el enfoque personalizado? [42](#defined-versus-customized-approach)

¿Sustituye un análisis de código abierto el escaneo ASV? [42](#does-an-open-source-scan-replace-asv-scanning)

¿Cómo verifica un requisito? [42](#how-do-you-verify-a-requirement)

¿Quién determina el nivel de validación de un comerciante? [42](#who-determines-a-merchants-validation-level)

¿Qué cambió para el comercio electrónico? [43](#what-changed-for-e-commerce)

25. Plantillas, Glosario e Índice [44](#templates-glossary-and-index)

25.1 Scope record [44](#scope-record)

25.2 Registro de pruebas de requerimiento [44](#requirement-evidence-record)

25.3 Glosario [44](#glossary)

25.4 Índice de asunto [45](#subject-index)

26. Referencias oficiales y estudio ulterior [46](#official-references-and-further-study)

1. PCI DSS v4.0.1 Fundaciones

El estándar actual, aplicabilidad, metas y limitaciones importantes.

■img src="media/image1.png" estilo="width:6.15in;height:3.94164in" alt="La seguridad del pago combina la red, el sistema, los datos, la identidad, física, el monitoreo, las pruebas y los controles de gobernanza".

Figura 1. Los doce requisitos de PCI DSS

1.1 Situación actual

- PCI DSS v4.0.1 fue publicado el 11 de junio de 2024, como una revisión limitada.
- La revisión aclaró y corrigió v4.0; no añadió ni suprimió los requisitos.
- PCI DSS v4.0 retirado 31 de diciembre de 2024.
- Las 51 necesidades por fecha futura entraron en vigor el 31 de marzo de 2025.
- A partir de la publicación de este manual de julio de 2026, PCI SSC está recopilando información de los interesados en v4.0.1; una solicitud de comentarios no es un nuevo estándar final.

1.2 A quién y a qué se aplica

PCI DSS se aplica a entidades que almacenan, procesan o transmiten datos de los titulares de tarjetas o datos de autenticación sensibles, y a entidades cuyos sistemas podrían afectar la seguridad del entorno de datos de los titulares de tarjetas. Los comerciantes, procesadores, compradores, emisores y proveedores de servicios pueden tener diferentes funciones de validación y presentación de informes.

1.3 Los seis objetivos de control

** Objetivo** Silencioso **Requisitos** |

|. | | Construir y mantener una red y sistemas seguros | 1-2 | Proteger los datos de la cuenta | Mantener un programa de gestión de la vulnerabilidad – Aplicación de medidas de control de acceso firmes tención Monitor y redes de pruebas periódicas Mantener una política de seguridad de la información

2. Normas de datos y protección de la cuenta

La diferencia entre los datos de los titulares de tarjetas, el PAN y los datos de autenticación sensibles.

■img src="media/image2.png" estilo="width:6.15in;height:2.98845in" alt="PAN es central para la aplicabilidad; los datos de autenticación sensible reciben un tratamiento de postautorización más estricto." /

Cuadro 2

Data |

...

----- | Número de Cuenta Primaria (PAN)
| Datos de titulares de tarjetas – Determine PCI DSS aplicabilidad cuando se almacenan, procesan o transmiten | Nombre del titular de la tarjeta | Datos del titular de la tarjeta | Fecha de publicación | Cardholder data | Protegido con PAN | | Código de servicio Silenciosos Datos de los titulares de tarjetas | Protegido | Datos completos de seguimiento | Datos de autenticación sensibles | No almacenar después de la autorización excepto expresamente permitido emisor uso | | Código de verificación de tarjetas/valor | Datos de autenticación sensibles TEN PIN/PIN block TENENCIA Datos de autenticación sensible TEN No almacene después de la autorización excepto expresamente permitido emisor uso |

2.1 Los métodos de protección son diferentes

- Limita la cantidad de PAN.
- La truncación elimina permanentemente un segmento del PAN en formatos definidos.
- Encryption hace que los datos no estén disponibles sin claves criptográficas protegidas.
- Hashing puede hacer que el PAN no esté listo cuando se implemente con el almacenamiento criptográfico y los controles adecuados.
- Tokenization replaces PAN with a value, but token systems and detokenization paths may remain in scope.
- Redaction elimina la información de una copia o vista; confirma que también se controlan los datos de origen y los metadatos ocultos.

Nunca utilice datos reales en el entrenamiento: Utilice los números de prueba del procesador de pago o valores inventados que no pueden confundirse con las cuentas reales. Nunca retenga SAD real después de la autorización. |

|. |

3. Alcance, ECM y Segmentación

Cómo encontrar a cada persona, proceso, tecnología y dependencia que pertenece a su alcance.

“A la altura: 2.99322in” alt=“Comenzar con flujos de cuenta-datos e incluyen sistemas conectados a los sistemas de impacto de seguridad y seguridad.” / Confeccionista

Figura 3. Flujo de análisis de PCI DSS

3.1 Scope discovery

1. Identificar todos los canales de pago: comercio electrónico, punto de venta, orden de correo/teléfono, facturación recurrente, centro de llamadas, móviles, quioscos y servicios externos.
2. Trace account data from collection through authorization, settlement, storage, reporting, support, backups, logs, disposal, and third parties.

3. Identificar sistemas de CDE, personas, procesos, instalaciones, servicios en la nube, aplicaciones, bases de datos, dispositivos de red, servicios de seguridad y vías administrativas.
4. Identificar sistemas y sistemas conectados que puedan afectar a la seguridad de la ECM, incluida la identidad, el DNS, el tiempo, el registro, el despliegue, la copia de seguridad, la virtualización, la vigilancia y las plataformas de gestión.
5. Identificar los controles de segmentación y todos los caminos que podrían evitarlos.
6. Confirmar responsabilidades, pruebas y ubicaciones de terceros.
7. Exclusiones de documentos, suposiciones, diagramas, inventarios y resultados de validación.

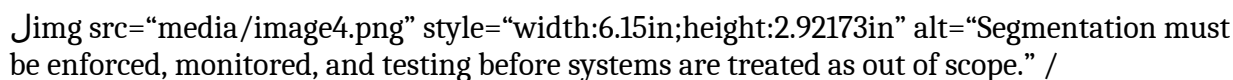


Figure 4. Segmentation and scope reduction

3.2 Validación del alcance

Validar el alcance al menos anual y después de un cambio significativo. Los proveedores de servicios realizan la confirmación de alcance documentada al menos una vez cada seis meses y después de un cambio significativo. Las pruebas deben intentar encontrar tiendas de datos desconocidas, caminos alternativos, activos no gestionados, servicios compartidos, dependencias de la nube, conexiones inalámbricas y acceso administrativo.

4. Validación, SAQs, ROC, AOC y Rols

Eligiendo el camino correcto de presentación de informes y el entendimiento que lo acepta.

Artifact or role | Purpose | **

|... | TEN SAQ A TENCIÓN Medios comerciales completamente subcontratados con tarjeta no presentes Elegibilidad es estricta; el comerciante sigue administrando el sitio web aplicable, el proveedor de servicios y los deberes de política TEN SAQ A-EP | comerciantes de comercio electrónico elegibles con un sitio web que puede afectar la seguridad de pago TEN Más requisitos se aplican porque la página de comerciante puede afectar a la transacción TEN SAQ B / B-IP TENCIÓN EJECUCIÓN EJECUCIONABLE O entornos terminales independientes específicos | No para el comercio electrónico; elegibilidad debe ser exacto TEN SAQ C / C-VT ANTE La aplicación de pago Elegible o entornos virtuales aislados Silencioso y restricciones de almacenamiento se aplican TEN SAQ P2PE | Mercadeos elegibles usando una solución PCI P2PE listada | Única solución validada uso y elegibilidad calificada TEN SAQ D Merchant ANTE Merchants not eligible for a shorter SAQ or directed to use it – Evaluación amplia de los requisitos aplicables | SAQ D Service Provider | Service providers permitted to self-assess where accepted TEN Service-provider requirements and customer responsibilities apply prehensi TEN ROC | Informe de evaluación detallado, generalmente completado por un QSA o ISA cuando sea

necesario | requerido basado en el programa de cumplimiento, nivel de validación o solicitud | TEN AOC ANTE Attestation summarizing assessment and compliance status TEN Debe corresponder al SAQ correcto o ROC y el alcance ANTE TEN ASV ANTE PCI SSC Aprobado Escáner Vendor para los escaneos de vulnerabilidad externa requeridos TEN El escaneo de código abierto no sustituye un escaneo ASV requerido TEN QSA / ISA | Evaluador calificado o roles de evaluador interno capacitados ANTERI Utilizar las calificaciones actuales y las instrucciones de aceptación de la entidad

Quién decide la validación: Las marcas de pago y los compradores establecen niveles de validación mercante y expectativas de presentación de informes. Los clientes y los contratos pueden establecer expectativas de proveedores de servicios. Confirme el método requerido antes de comenzar. |

|.

5. Definidos, personalizados, compensatorios y enfoques de riesgo

Conseguir flexibilidad sin debilitar el objetivo del requisito.

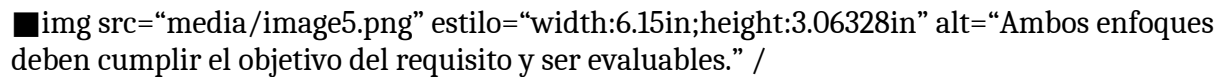
■  src="media/image5.png" estilo="width:6.15in;height:3.06328in" alt="Ambos enfoques deben cumplir el objetivo del requisito y ser evaluables." /

Gráfico 5 Enfoques definidos y personalizados

Method | Cuando se utiliza | **

|. | Definido acercamiento | Entity implementa el requisito declarado – Requisitos pruebas y procedimientos oficiales de prueba | Enfoque personalizado | Entity diseña un control diferente que cumple con el objetivo personalizado de matriz de control Silencioso, análisis de riesgos, diseño, dependencias, pruebas, pruebas de funcionamiento, validación del evaluador | Control compensatorio | Una limitación técnica o empresarial legítima impide el requisito declarado TEN Constraint, objetivo, riesgo adicional, control compensatorio, mantenimiento, validación, revisión anual | | Análisis de riesgo focalizado — frecuencia | Un requisito permite a la entidad definir con qué frecuencia se produce una actividad TENA, amenazas, probabilidad, impacto, racionalidad, frecuencia, propietario, aprobación, revisión anual | tención Análisis de riesgos orientados — personalizado tención apoya el diseño y validación de control personalizado — Amenazas, suposiciones, objetivo de control, diseño, riesgo residual, pruebas, pruebas latitud

El enfoque personalizado no es compatible en cada SAQ o contexto de requisitos.

Un control compensatorio no es un atajo por costo o conveniencia.

El análisis de riesgos apuntado no elimina un requisito; apoya una decisión permitida.

Confirme las expectativas de aceptación y evaluación antes de comprometerse a un enfoque.

6. Requisitos 1 - Controles de Seguridad de la Red

Install and Maintain Network Security Controls

Propósito de la solicitud: Instalar y mantener los controles de seguridad de la red |... |

Grupo

1.1

1.2

tención 1.3

TEN 1.4 TENCIÓN Las conexiones de control entre las redes confiables y no confiadas, incluyendo las protecciones contra el soborno y la divulgación. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. Diagramas de red, flujos de datos, conjuntos de reglas, aprobaciones, exámenes de seis meses, exportaciones de configuración | 1.5 | Protege los dispositivos informáticos que se conectan a las redes no confiadas y al CDE. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. Diagramas de red, flujos de datos, conjuntos de reglas, aprobaciones, exámenes de seis meses, exportaciones de configuración

**** Nota de evaluación **** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

7. Requisito 2 - Configuraciones seguras

Apply Secure Configurations to All System Components

Propósito de solicitud: Aplicar Configuraciones seguras a todos los componentes del sistema |
|... |

Grupo

tención 2.1

Ø 2.2 tención Desarrollar y aplicar normas de configuración; eliminar defectos, servicios innecesarios y ajustes inseguros. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. estándares de configuración, inventarios, escaneos de endurecimiento, reseñas de cuenta predeterminada y de servicio

tención 2.3 – Ambientes inalámbricos seguros con defectos cambiados, criptografía fuerte y ajustes gestionados. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. estándares de configuración, inventarios, escaneos de endurecimiento, reseñas de cuenta predeterminada y de servicio

**** Nota de evaluación **** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

8. Requisitos 3 - Datos de la cuenta almacenada

Protect Stored Account Data

Propósito de la solicitud: Proteger los datos de la cuenta almacenada |... |

Grupo

tención 3.1

3.2

tención 3.3

3.4

TEN 3.5 Ø Render guardó PAN inalcanzable utilizando métodos aprobados y protegiendo cualquier mecanismo relacionado. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. inventario de datos, calendario de retención, resultados de descubrimiento, cifrado y registros de gestión clave | 3.6 | Protege las claves criptográficas utilizadas para asegurar los datos de la cuenta almacenada. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. inventario de datos, calendario de retención, resultados de descubrimiento, cifrado y registros de gestión clave | 3.7 – Operar procesos completos de ciclo de vida de gestión clave. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. inventario de datos, calendario de retención, resultados de descubrimiento, cifrado y registros de gestión clave |

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

Prohibición crítica Los datos de autenticación sensibles no deben almacenarse después de la autorización, incluso cuando estén encriptados, salvo cuando PCI DSS permita expresamente el uso de emisor o soporte de emisión. |. |

9. Requisement 4 — Transmission Cryptography

Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks

Propósito de solicitud: Proteger los datos de los titulares de tarjetas con una fuerte criptografía durante la transmisión a través de redes públicas |

|... |

Grupo

tención 4.1

TEN 4.2

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

Requisito 5 - Software malicioso

Proteger todos los sistemas y redes del software malicioso

Propósito de la adquisición: Proteger todos los sistemas y redes del software malicioso | ... |

Grupo | Significado claro | Enfoque de verificación | Evidencia de ejemplo |

La inmortalidad

----- | 5.1 | Definir, asignar y documentar procesos y roles antimalware. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. Evaluación de riesgo de malware, cobertura de agentes, políticas, alertas, actualizaciones, controles de phishing TEN 5.2 TENCIÓN Evitar, detectar y eliminar el malware en sistemas generalmente afectados o evaluados periódicamente como no en riesgo. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. Evaluación de riesgo de malware, cobertura de agentes, políticas, alertas, actualizaciones, controles de phishing | 5.3 | Mantener mecanismos antimalware activos, actuales, protegidos, conectados, monitoreados y limitados a la desactivación autorizada. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. Evaluación de riesgo de malware, cobertura de agentes, políticas, alertas, actualizaciones, controles de phishing TEN 5.4 | Utilizar mecanismos automatizados y procesos de capacitación para proteger al personal de los ataques de phishing. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. Evaluación de riesgo de malware, cobertura de agentes, políticas, alertas, actualizaciones, controles de phishing

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

11. Requisito 6 - Sistemas seguros y software

Desarrollar y mantener sistemas y software seguros

Propósito de la adquisición: Desarrollar y mantener sistemas y software seguros | ... |

Grupo

tención 6.1

TEN 6.2

TEN 6.3

tención 6.4

TEN 6.5

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

■img src="media/image6.png" estilo="Ancho:6.15in; Altura:3.05in" alt="Inventario, autoriza, valida, monitor, y responde a cambios de script y encabezado de página de pago." /

6. Protección de las páginas de pago del comercio electrónico

Las necesidades 6.4.3 y 11.6.1 son ahora eficaces. Mantener un inventario y una justificación comercial o técnica para los scripts de página de pago, autorizarlos, asegurar su integridad y desplegar la detección de cambios/tamper para las páginas pertinentes y los encabezados HTTP al menos con la frecuencia necesaria o apoyada por el análisis de riesgo específico permitido.

12. Requisito 7 - Necesidad de los negocios

Restrict Access to System Components and Cardholder Data by Business Need to Know

Propósito de la adquisición: Restringir el acceso a los componentes del sistema y los datos de los titulares de tarjetas por parte de las empresas Necesita saber |

| ... |

Grupo

7.1

TEN 7.2

TEN 7.3

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

13. Requisito 8 - Identidad y autenticación

Identificar a los usuarios y Autentizar el acceso a los componentes del sistema

Propósito de solicitud: Identificar a los usuarios y Autentizar el acceso a los componentes del sistema |

| ... |

Grupo

8.1

TEN 8.2

8.3

8.4

Grupo

tención 8.5

TEN 8.6

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

- Recordatorio de la autenticación* Requirement 8 contiene reglas detalladas para IDs únicos, cuentas inactivas y terminadas, contraseñas fuertes/passphrases, MFA, cuentas de servicio, factores de autenticación y reseteo seguro. Verifique la aplicabilidad exacta en el estándar oficial. |. |

Requisito 9 - Acceso físico

Restrict Physical Access to Cardholder Data

Propósito de la solicitud: Restringir el acceso físico a los datos del titular de la tarjeta |

|... |

Grupo

TEN 9.1

TEN 9.2

9.3

9.4

9.5

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

15. Requisitos 10 - Logging and Monitoring

Log and Monitor All Access to System Components and Cardholder Data

Propósito de solicitud: Iniciar sesión y vigilar todo el acceso a los componentes del sistema y los datos de los titulares de tarjetas |

|... |

Grupo

TEN 10.1

TEN 10.2 TER Generar registros de auditoría que apoyen la detección de anomalías, la rendición de cuentas, la investigación y los forenses. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest.

TEN 10.3

Grupo

TEN 10.4

TEN 10.5

TEN 10.6

10.7

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

Requisitos 11 - Pruebas de seguridad

Procesos y sistemas de seguridad ordinarios

Propósito de solicitud: Sistemas de seguridad de pruebas y procesos regularmente |

|...|

Grupo

TEN 11.1

11.2

TEN 11.3

TEN 11.4

11.5

TEN 11.6 Ø Detectar y responder a cambios no autorizados en las páginas de pago y en los encabezados HTTP de impacto en la seguridad. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. TEN resultados inalámbricos, reportes de escaneo, evidencia ASV, pruebas de penetración, alertas IDS/FIM, monitorización del cambio de página

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

No sustituyan las herramientas Los escáneres de vulnerabilidad comunitaria pueden apoyar el trabajo interno pero no sustituir el requisito de pasar escáneres ASV externos. Los escáneres web automatizados no reemplazan las pruebas de penetración requeridas ni la evaluación manual calificada. | |.

17. Requirement 12 — Policies and Programs

Apoyo Seguridad de la Información con Políticas y Programas Organizacionales

Propósito de solicitud: Apoyo a la seguridad de la información con las políticas y programas de organización |.

Grupo

TEN 12.1

tención 12.2

TEN 12.3

TEN 12.4

TEN 12.5

12.6

TEN 12.7 ANTERIED Screen prospective personnel who will have access to the CDE, subject to law and role risk. tención Confirme el alcance, propiedad, diseño, implementación, evidencia operativa, excepciones, corrección y retest. políticas, análisis de riesgos, validación de alcances, capacitación, control de personal, archivos TPSP, ejercicios de incidentes

TEN 12.8

12.9

12.10

**** Nota de evaluación**** Utilice el texto oficial PCI DSS v4.0.1 y el modelo de presentación de informes aplicable para requisitos exactos, notas de aplicabilidad, procedimientos de prueba, opciones de respuesta y documentación. Este manual explica; no reemplaza el estándar.

'img src="media/image7.png" style="width:6.15in;height:2.70151in" alt="Detect, contenga, analice, notifique, recupere y mejore el uso de responsabilidades y contactos preparados.

Gráfico 8 Corriente de trabajo de respuesta a incidentes de pago

18. Pruebas, evaluación y control

Cómo verificar que los requisitos PCI DSS se implementan y operan.

■img src="media/image8.png" style="width:6.15in;height:2.84492in" alt="Una conclusión defensible conecta criterios, alcance, diseño de control, evidencia completa, pruebas, corrección y retest." /

√ Figure 7. Requirement-to-evidence chain

- Definir el requisito exacto, aplicabilidad, alcance, control, propietario, sistemas, ubicaciones, período, frecuencia y pruebas esperadas.
- Evaluar el diseño: ¿el control cumpliría razonablemente el objetivo definido o personalizado?
- Obtener la población completa y validar la integridad y exactitud contra fuentes independientes.
- Seleccione una muestra basada en el riesgo que cubra las fechas, activos, propietarios, fallos, excepciones, cambios y proveedores de servicios pertinentes.

- Inspeccione configuraciones, registros, observaciones, entrevistas y datos del sistema; vuelva a funcionar cuando sea práctico.
- Excepciones de documentos con criterios, hechos, duración, datos y sistemas de cuentas afectados, causa, impacto y protección existente.
- Remediación de asignación, protección provisional, propietario, recursos, fecha límite y escalada.
- Reprueba la corrección en toda la población afectada y establece la conclusión y limitaciones.

18.1 Pruebas prácticas

Area | Población y muestra | **

|, silencio. | Todas las vías de pago, los sistemas, las tiendas de datos, los proveedores y las trayectorias de segmentación Ø Reconcile diagramas e inventarios a la red, identidad, nube, descubrimiento, adquisición y fuentes de apoyo ANTERI flujos de datos, inventario, resultados de descubrimiento, pruebas de segmentación, alcance firmado Reglas de la Red Silencioso Todas las reglas conectadas con CDE; cambios de muestra, reglas temporales y reseñas – Necesitas negocios de Trace, aprobación, implementación, revisión, expiración y comportamiento de tráfico TEN Regla exportar, ticket, propietario, revisión, prueba y eliminación tención, eliminación, renderización del PAN, protección clave, prohibición del SAD y controles remotos de la copia Ø Discovery, muestras, configuración, eliminación y registros clave – Acceso | Todos los trabajadores, privilegios, servicios, aplicaciones y cuentas de terceros Necesidades de prueba, aprobación, MFA, autenticación, revisión, cambio, inactividad y rescisión TENRI Población, configuración, registros, aprobaciones, revisiones y entradas ANTERI TEN Vulnerabilities TEN Todos los activos y hallazgos del in-scopio ANTE Validar cobertura, escaneo autenticado, clasificación de riesgos, parche, estado ASV, excepción, y rescane ANTE Inventory, ajustes de escaneo, informes, entradas, aprobación de pruebas ASV tención Registros | Todas las fuentes, comentarios, alertas, retención y fallos de control requeridos Campos de prueba, protección, tiempo, frecuencia de revisión, automatización, investigación y respuesta a fallos | Lista de fuentes, configuraciones, alertas, entradas, retención y prueba de tiempo – Páginas de pago | Todos los scripts, páginas, encabezados, cambios y alertas | Autorización de prueba, justificación, integridad, inventario, monitoreo, frecuencia, alerta y respuesta TENIS Script inventario, aprobaciones, método de integridad, alerta, ticket y retest – Terceras partes – Población completa del TPSP; muestra crítica, nueva, cambiada y terminada proveedores Acuerdo de prueba, matriz de responsabilidad, estado, vigilancia, derechos de incidencia, efecto de alcance y salida TEN-Inventario, contratos, AOCs, matriz, revisiones, hallazgos y prueba de eliminación

19. Herramientas de código abierto para el trabajo PCI DSS

- Enlaces oficiales, inicios rápidos seguros, pruebas y limitaciones.*

Herramienta

CISO Assistant

Herramienta

tención Wazuh

Silencioso osquery

OpenSCAP – Evaluación de la configuración segura de Linux

Greenbone Community Edition

Nmap

tención Trivy

OWASP ZAP

Silencioso ModSecurity + OWASP CRS durable Controles de firewall de aplicaciones web | Suricata Silencioso Red de detección de intrusiones | TENER Keycloak | Identidad, acceso, MFA y autenticación – DefectDojo | Encontrar la ingesta, la remediación y la retesta | 6, 11, 12 | AIDE | Monitorización de la integridad de archivos – Política Abierta Agente Silencioso Política como código

- Limitación crítica* Estas herramientas pueden apoyar pruebas y operaciones de seguridad. No pueden hacer que una entidad PCI DSS cumpla, reemplazar un juicio QSA/ISA, reemplazar los escaneos ASV requeridos, o reemplazar las pruebas de penetración calificadas. | |.

19.1 validación de herramientas

- Aprobar propósito, alcance, sistemas, datos, propiedad, alojamiento, acceso y retención.
- Verificar fuente oficial, versión, dependencias, integridad, actualizaciones y configuración segura.
- Crear una condición conocida la herramienta debe detectar o bloquear y una condición permitida conocida.
- Compare agente, activo, repositorio, objetivo, identidad o cobertura de registro con una población independiente.
- Proteger credenciales administrativas, informes, reglas, registros y respaldos.
- Definir el examen humano, la escalada, la corrección, la excepción y la prueba.
- Revalidate después de cambios, mejoras, cambios de integración o fracasos.

19.2 CISO Assistant

GRC, requisitos, evidencia, riesgos. Posible apoyo PCI DSS: 12, todos.

Documentación oficial: Abra la guía oficial de asistentes CISO(<https://intuitem.gitbook.io/ciso-assistant>)

Inicio rápido

Crear un comerciante ficticio, mapear cinco grupos de requisitos, asignar propietarios, adjuntar evidencia sanitaria, y rastrear una brecha a través de la prueba.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.3 Wazuh

Seguridad Endpoint, malware, registros, integridad. Posible apoyo PCI DSS: 5, 10, 11.

Documentación oficial: Abra la guía oficial Wazuh realizada/u título](<https://documentation.wazuh.com/current/quickstart.html>)

Inicio rápido

Conectar un endpoint de laboratorio autorizado, generar un evento inofensivo, revisar la alerta y retener el evento, regla, revisión y ticket.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.4 osquery

Consultas de activos, software, cuenta y configuración. Posible apoyo PCI DSS: 2, 5, 8, 10.

Documentación oficial: [Seguido]Abre la guía oficial del osquery realizada/u contacto] (<https://osquery.readthedocs.io/en/stable/>)

Inicio rápido

Usuarios de laboratorio de consulta, software, servicios, cifrado o procesos; mantener consultas, población de acogida, tiempo, salida y revisión.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.5 OpenSCAP

Evaluación de configuración segura de Linux. Posible apoyo PCI DSS: 2, 6.

Documentación oficial: [Seguido]Abre la guía oficial OpenSCAP efectuada/u contacto] (<https://www.open-scap.org/getting-started/>)

Inicio rápido

Evaluar un laboratorio Linux aprobado contra un perfil adecuado, corregir un ajuste aprobado y comparar informes.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.6 Greenbone Community Edition

Evaluación interna de la vulnerabilidad. Posible apoyo PCI DSS: 6, 11.

Documentación oficial: [Seguridad]Abre la guía oficial Greenbone Community Edition realizada/u contacto] (<https://greenbone.github.io/docs/latest/>)

Inicio rápido

Escanear sólo un objetivo de laboratorio aprobado, validar un hallazgo, corregirlo, cambiar y documentar cobertura y límites.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.7 Nmap

Servicio autorizado y descubrimiento de segmentación. Posible apoyo PCI DSS: 1, 2, 11.

Documentación oficial: [Seguridad]Abre la guía oficial Nmap realizada/u contacto] (<https://nmap.org/book/man.html>)

Inicio rápido

Escanee un pequeño rango de laboratorio autorizado, compare los servicios observados con el inventario, y registro de alcance y aprobación.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.8 Trivy

Código, imagen, dependencia, secreto y análisis de configuración. Posible apoyo PCI DSS: 6.

Documentación oficial: Abra la guía oficial Trivy realizada/u título](<https://trivy.dev/latest/>)

Inicio rápido

Escanee una imagen de laboratorio o un repositorio de prueba, proteja la salida, valide un hallazgo, corrija y escanee de nuevo.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.9 OWASP ZAP

Evaluación autorizada de la aplicación web. Posible apoyo PCI DSS: 6, 11.

Documentación oficial: Abra la guía oficial OWASP ZAP efectuada / u fiel](<https://www.zaproxy.org/getting-started/>)

Inicio rápido

Proxy a local training application, start with passive analysis, validate a result, and keep scope and evidence.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.10 ModSecurity + OWASP CRS

Controles de firewall de aplicación web. Posible apoyo PCI DSS: 6.4.2.

Documentación oficial: Abrir la guía oficial ModSecurity + OWASP CRS indica/u contacto](<https://coreruleset.org/docs/>)

Inicio rápido

Deplorar sólo en un laboratorio, grabar versión y modo regla, probar una solicitud inofensiva, sintonizar un falso positivo, y preservar la aprobación del cambio.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.11 Suricata

Detección de intrusión en red. Posible apoyo PCI DSS: 11.5.

Documentación oficial: [Seguridad]Abre la guía oficial de Suricata realizada/u contacto] (<https://docs.suricata.io/>)

Inicio rápido

Monitorear un segmento de laboratorio aislado, desencadenar una alerta de prueba inofensiva, y regla de documentos, fuente de tráfico, alerta, revisión y respuesta.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.12 Keycloak

Identidad, acceso, MFA y autenticación. Posible apoyo PCI DSS: 7, 8.

Documentación oficial: [obedeció]Abre la guía oficial de Keycloak realizada/u contacto] (<https://www.keycloak.org/guides>)

Inicio rápido

Crear un ámbito de laboratorio, roles, usuarios y MFA; probar menos privilegios, acceso fallido, revisión y terminación.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.13 DefectoDojo

Encontrar la ingesta, la remediación y la retesta. Posible apoyo PCI DSS: 6, 11, 12.

Documentación oficial: [Seguido]Abre el defecto oficialDojo guía seleccionada/u contacto](<https://docs.defectdojo.com/>)

Inicio rápido

Importar un análisis de laboratorio, validar y asignar un hallazgo, registrar la remediación, retestar y cerrar con evidencia.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.14 AIDE

Monitoreo de integridad de archivos. Posible apoyo PCI DSS: 11.5.2.

Documentación oficial: Abra la guía oficial AIDE realizada/u título](<https://aide.github.io/>)

Inicio rápido

Crear una base de referencia en un host de laboratorio desechable, hacer un cambio de archivo autorizado, revisar la alerta, restaurar y documentar el proceso.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

19.15 Open Policy Agent

Política como código. Posible apoyo PCI DSS: 2, 6, 7.

Documentación oficial: [Seguridad]Abre la guía oficial de Agentes de Políticas Abiertas efectuada/u contacto](<https://www.openpolicyagent.org/docs>)

Inicio rápido

Cree una política de laboratorio que niegue el despliegue sin un propietario, clasificación, una red aprobada y un estado de exploración de seguridad.

Evidencia y limitación

Retener autorización, propósito, población objetivo completa, versiones, configuración, resultado bruto, revisor, decisión, acción correctiva, excepción y retest. Proteger resultados que contengan PAN, credenciales, arquitectura, identidades o vulnerabilidades. Nunca coloque datos de cuenta real en una herramienta no aprobada.

20. Manual de PCI DSS para gerentes

Las preguntas, los paneles, la propiedad y los administradores de decisiones deben controlarse.

20.1 Preguntas mensuales

¿Cambiaron canales de pago, flujos de datos, sistemas, proveedores, scripts, servicios en la nube o rutas administrativas?

¿El alcance está completo y validado, incluyendo sistemas conectados y de impacto en la seguridad?

¿Ha aparecido algún dato de cuenta donde no se esperaba?

¿Son hallazgos de alto riesgo, controles fallidos, resultados ASV, pruebas de penetración y remediación a tiempo?

¿Se entienden las responsabilidades del proveedor de servicios y las pruebas actuales de cumplimiento?

¿Se revisan los scripts de página de pago y las alertas de detección de cambios?

¿El acceso, MFA, registro, malware, parches, copias de seguridad y controles de incidentes funcionan consistentemente?

¿Qué limitaciones o excepciones no resueltas deben ser el liderazgo y la entidad aceptante sabe?

20.2 Panel

Area | **** Cuestión del personal**** | ... | ¿Están presentes todos los canales, datos, sistemas, caminos, proveedores y scripts? Verde / Amarillo / Rojo | ¿Se minimiza el almacenamiento y el tratamiento PAN/SAD correcto? Verde / Amarillo / Rojo | | Red/configuración ¿Son reglas, endurecimiento, revisiones y segmentación operando? Verde / Amarillo / Rojo | | Acceso ANTE ¿Es necesario, MFA, cuentas, revisiones y control de terminación? Verde / Amarillo / Rojo | ¿Son parches, escaneos, resultados de ASV, pruebas de penetración y pruebas actualizadas? Verde / Amarillo / Rojo — Monitorización | ¿Se revisan registros, alertas, integridad, IDS, fallos de control y páginas de pago? Verde / Amarillo / Rojo | Terceras partes ¿Son controladas las responsabilidades, el estado, la vigilancia, los incidentes y las salidas? Verde / Amarillo / Rojo | | Respuesta ¿Se han probado, aumentado, preservado, comunicado y mejorado los incidentes de pago? Verde / Amarillo / Rojo |

21. Desde el principiante hasta el analista Junior PCI

Un camino seguro y honesto hacia el cumplimiento de la seguridad de pago.

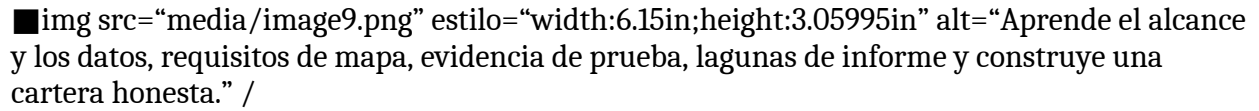
■  `src="media/image9.png" estilo="width:6.15in;height:3.05995in" alt="Aprende el alcance y los datos, requisitos de mapa, evidencia de prueba, lagunas de informe y construye una cartera honesta." /`

Figura 9. Vía de analista Junior PCI

Junior PCI Compliance Analyst

GRC Analyst — Payments

**** Analista de Controles de Seguridad ****

Coordinador de evidencias de PCI

- Análisis del riesgo de las tres partes*

**** Analista de Gestión de la Vulnerabilidad ****

**** Analyst de Seguridad de Seguridad ****

**** Analyst de Seguridad del Payment ****

21.1 Típico trabajo junior

- Mantener un canal de pago, flujo de datos, sistema, proveedor, cuenta, script e inventarios de pruebas.
- Reunir y organizar pruebas sin alterar los registros de fuentes.
- Examinar muestras para reglas de red, configuraciones, acceso, MFA, parches, registros, capacitación y supervisión de proveedores.
- Seguimiento de escáneres ASV, escaneos internos, pruebas de penetración, hallazgos, excepciones, remediación y retests.
- Validación del alcance de soporte, descubrimiento de datos, matrices de responsabilidad y ejercicios de incidentes.
- Escribir conclusiones claras sin reclamar autoridad evaluadora.
- Proteger los datos de cuenta y seguir los límites de autorización.

22. Laboratorio Ficcional y Portfolio

Un entorno de práctica completo utilizando datos sintéticos y sistemas de laboratorio autorizados.

Harbor Light Market es un comerciante ficticio con una página de pago anfitriona, dos terminales de punto de venta, un centro de llamadas, colaboración en la nube, un proveedor de servicios gestionado y un procesador ficticio. Todos los números de cuenta, personas, sistemas, alertas y proveedores se inventan o aprueban datos de prueba.

Project 1 — Scope

Map channels, account data, CDE, connected systems, security-impacting systems, providers, and segmentation.

Proyecto 2 - Requisitos

Crear una matriz de responsabilidad y evidencia de 12 requisitos.

Project 3 — Data

Ejecutar un ejercicio de descubrimiento de datos sintético y retención de documentos, eliminación y protección del PAN.

Project 4 — Access

Test ficticio, impulsor, levadura, privilegiado, cuenta de servicio y evidencia MFA.

Proyecto 5 - Vulnerabilidades

Realizar un análisis autorizado de laboratorio, validar, corregir, reescanear y explicar por qué la evidencia ASV es separada.

Project 6 — E-commerce

Los scripts de pago sintético de inventario, los justifican y autorizan, validan la integridad y prueban una alerta de cambio inofensiva.

Project 7 — Incident

Ejecutar una mesa que implica un PAN inesperado y un script de pago cambiado; preservar los hechos, escalar, contener, recuperar y mejorar.

Project 8 - Management report

Prepare scope, status, top gaps, action plan, decisions, and limitations.

Portfolio ethics:* Etiqueta cada artículo como entrenamiento de ficción. Nunca publique PAN real, SAD, datos de clientes, credenciales, arquitectura de pago, resultados de escaneo, incidentes, contratos o informes de evaluación. | |.

23. Plan de aprendizaje de 30 días

Un mes realista de lectura oficial, evidencia práctica y preparación de entrevistas.

Week | **

...----- |
Semana 1 | Fundaciones, datos de cuenta, alcance, segmentación, validación sometida Scope
memo, mapa de datos, inventario, preguntas de decisión SAQ Silenciosa Semana 2 1-6 |
Network/configuration evidence, data rules, patch and software-security test tención
Requisitos para la vida cotidiana 7-12 examen de acceso Silencioso, examen de registro, archivo
de exploración, matriz de proveedores, tabletop de incidentes | Semana 4 | Herramientas,
portafolio, reportajes, entrevista | Portafolio Sanitario, dashboard, respuestas practicadas

24. Preparación de entrevistas

Respuestas rápidas y precisas para analistas y administradores junior.

¿Cuál es la versión actual PCI DSS?

PCI DSS v4.0.1. Fue publicado en junio de 2024 como una revisión limitada. PCI DSS v4.0 retirado a finales de 2024, y los requisitos de v4.x de fecha futura entraron en vigor el 31 de marzo de 2025.

¿Cuál es el CDE?

Las personas, procesos y tecnologías que almacenan, procesan o transmiten datos de los titulares de tarjetas o datos de autenticación sensibles, además de los sistemas pertinentes que se conectan o pueden afectar su seguridad.

¿Qué es PAN?

El número de cuenta primaria. Su presencia es central en la aplicabilidad PCI DSS.

¿Pueden almacenarse datos de autenticación sensibles si están encriptados?

No después de la autorización, excepto cuando PCI DSS permite expresamente el uso de emisor o soporte de emisión.

¿Qué es la segmentación?

Controles que aíslan el CDE. Reduce el alcance sólo cuando se documentan y prueban el diseño y la eficacia.

¿Definido contra enfoque personalizado?

El enfoque definido sigue el requisito establecido. Un enfoque personalizado utiliza otro diseño de control que cumple con el objetivo personalizado y requiere un amplio riesgo, diseño, evidencia y validación del evaluador.

¿Sustituye un análisis de código abierto el escaneo ASV?

No. Los escaneos de vulnerabilidad externa requeridos deben realizarse a través de un proveedor de escaneado aprobado y cumplir con los requisitos del programa.

¿Cómo verificas un requisito?

Definir criterios y alcance, evaluar el diseño, obtener una población completa, probar elementos representativos, registrar excepciones, remediar, retestar y limitaciones estatales.

¿Quién determina el nivel de validación de un comerciante?

Las marcas de pago y los compradores establecen programas de cumplimiento y expectativas de validación; contratos y clientes pueden añadir requisitos.

¿Qué cambió para el comercio electrónico?

Los requisitos 6.4.3 y 11.6.1 requieren una mejor gobernanza de los scripts de página de pago y la detección de cambios no autorizados en las páginas y encabezados pertinentes.

Respuesta de 60 segundos del administrador: Empiezo con canales de pago y flujos de datos de cuenta, definir el verdadero CDE y sistemas que pueden afectarlo, confirmar el camino correcto de validación, asignar la propiedad del requisito y exigir pruebas operativas completas. Minimizamos los datos, el acceso de control y los proveedores, protegemos las páginas de pago, escaneamos y probamos de acuerdo con las reglas de PCI, remediamos y retestamos los hallazgos, e intensificamos los incidentes rápidamente. Los instrumentos apoyan la labor, pero el alcance, las pruebas, el juicio del evaluador y la rendición de cuentas de la administración determinan si las conclusiones son fiables. |

RespuestaRespuesta

25. Plantillas, Glosario e Índice

Reusable structures and plain-English definitions.

25.1 Scope record

- Canal de pago, propósito, propietario, ubicación y flujo de transacción
- PAN, CHD, SAD, almacenamiento, procesamiento, transmisión, retención y eliminación
- Sistemas de CDE, sistemas conectados a sistemas, sistemas de seguridad, personas, procesos e instalaciones
- Redes, nube, identidad, registro, tiempo, respaldo, apoyo, implementación, herramientas de seguridad y vías administrativas
- TPSPs, servicios, datos, acceso, ubicaciones, subcontratistas, responsabilidades y pruebas de cumplimiento
- Diseño de segmentación, puntos de ejecución, monitoreo, pruebas, caminos de circunvalación y conclusión
- Cambios, supuestos, exclusiones, limitaciones, fecha de validación, aprobador y próximo examen

25.2 Requirement evidence record

- Requisitos y enfoque
- Aplicabilidad y racionalidad
- Control, propietario, frecuencia, sistemas y periodo
- Pruebas esperadas y población completa
- Muestra y procedimiento
- Resultados, excepciones, causa, riesgo, remediación, protección provisional y fecha
- Retest, conclusión, revisor, aprobación y limitación

25.3 Glosario

AOC. Atestiguación del cumplimiento.

Venta. Un proveedor de escáner aprobado por PCI SSC.

**** Datos del titular de la tarjeta.**** PAN más nombre relacionado del titular de la tarjeta, fecha de caducidad o código de servicio.

CDE. El entorno de datos del titular de la tarjeta.

Control compensador. Una alternativa documentada utilizada cuando una limitación legítima impide cumplir un requisito definido, protegiendo al mismo tiempo el objetivo del requisito.

**** Enfoque personalizado.**** Un enfoque de control diseñado por la entidad que cumple con un objetivo personalizado PCI DSS y requiere documentación adicional y validación.

PAN. Número de cuenta primaria.

QSA. Evaluador de Seguridad Calificado.

ROC. Informe sobre el cumplimiento.

SAD. Datos de autenticación sensibles: datos completos, códigos de verificación/valores y bloques PIN/PIN.

**** Cuestionario de autoevaluación.**

Segmentación. Los controles utilizados para aislar el CDE y potencialmente reducir el alcance.

Evaluación del riesgo. Un análisis PCI DSS v4.x apoyando decisiones de frecuencia especificadas o controles personalizados.

TPSP. Proveedor de servicios de terceros.

25.4 Índice de asunto

Tema Silencioso** | ————— | — Datos de la cuenta Silencioso 2, 8–9 | ASV | 4, 16, 18–19 ANTERIOR PAN | 2, 8 | — La autenticación Silencioso 13, 18–19 | CDE | 1–3, 18 Silenciosos SAQ — Controles compensatorios Silencioso 5 Silencioso | Enfoque personalizado | 5 ANTE Segmentation TEN 3, 16, 18 | E-commerce | 11, 16, 18 Silenciosos datos de autenticación sensibles — Evidencia | 18–20 proveedores de servicios Silenciosos 3–4, 17–18 | Respuesta del incidente | 17, 22 | Análisis de riesgos orientados Silencioso analista junior Silencioso 21–24 | Vulnerability escanea | 11, 16, 18–19 | | TERRITORIO TENENCIA 15, 18–19 ANTERIOR |

26. Referencias oficiales y estudio ulterior

- Fuentes actuales de PCI SSC y documentación oficial de herramientas utilizada para la verificación.*

Se indica

[](<https://blog.pcisecuritystandards.org/pci-dss-v4-0-resource-hub>)

[Seguido]Publicado: PCI DSS v4.0.1 interpretado/u
fiel](<https://blog.pcisecuritystandards.org/just-published-pci-dss-v4-0-1>)

Seguido

No

Seguridad de la página de envío y prevención de E-Skimming asignado/u contacto

[
]](https://www.pcisecuritystandards.org/assessors_and_solutions/qualified_security_assessors)

[
]](https://www.pcisecuritystandards.org/assessors_and_solutions/approved_scanning_vendors)

tención **Recordaje final:** Publicaciones PCI SSC, FAQs, formularios, guía, listados de evaluadores, programas de marca de pago, instrucciones de adquisición, contratos, tecnologías y cambios de amenazas. Confirme el estándar oficial actual y la ruta de presentación de informes antes de una evaluación real. | | . |